

Ubuntu 24.04 LTS Security Compliance Assessment Report

Course: Cybersecurity Legislation and Compliance Assessments

Module: Module 7 – Technical Compliance | **Lab:** OpenSCAP Security Scanning

Student: HASSANI Mohammad Salem

Date: January 25, 2026

Instructor: Asen Grozdanov

NorthStream – Compliance Scan Analysis (OpenSCAP)

Target: Ubuntu 24.04 VM (authorized lab environment)

Scanner: OpenSCAP (oscap) with SCAP Security Guide content (CIS/NIST-aligned profile).

Scan outputs: ARF XML + HTML report exported to /tmp (copied to Desktop).

Executive Summary

OpenSCAP scan identified multiple high-severity configuration gaps related to authentication, boot security, and time synchronization. These gaps increase risk of unauthorized access (local and remote) and reduce forensic reliability. Remediations are straightforward and align with common baseline hardening standards.

Quantitative Results Summary

Metric	Value
Total rules evaluated	N/A (not provided)
Passed	N/A
Failed	N/A (at least 5 high-severity failures shown)
Errors/Unknown	N/A
Overall compliance score	N/A

Detailed Finding Analysis (High Priority)

• Prevent Login to Accounts With Empty Password (High)

Field	Detail
Rule ID	xccdf_org.ssgproject.content_rule_no_empty_passwords_unix
Current State	PAM config contains 'nullok' in /etc/pam.d/common-auth
Required State	Remove nullok so empty passwords are rejected
Risk / Threat Scenario	Any account with empty password allows unauthenticated local login; attacker can escalate privileges.
Compliance Mapping	PIPEDA: safeguards appropriate to sensitivity; NIST 800-53 AC-2/AC-7; CIS controls for authentication.
Remediation (commands)	Edit /etc/pam.d/common-auth and remove 'nullok' option from pam_unix.so line, then test login.

• Set the UEFI Boot Loader Password (High)

Field	Detail
Rule ID	xccdf_org.ssgproject.content_rule_grub2_uefi_password
Current State	No grub superuser/password defined in /boot/grub/grub.cfg
Required State	Add grub2 superuser and password_pbkdf2 entry in /etc/grub.d/40_custom and run update-grub
Risk / Threat Scenario	Physical access can allow boot parameter changes or single-user mode; bypasses OS controls.
Compliance Mapping	NIST 800-53 PE-3/PE-6 (physical access); HIPAA 164.310(d); CIS bootloader hardening.
Remediation (commands)	Run grub2-mkpasswd-pbkdf2, add set superusers and password_pbkdf2 to /etc/grub.d/40_custom, then sudo update-grub.

• Enable systemd_timesyncd Service (High)

Field	Detail
Rule ID	xccdf_org.ssgproject.content_rule_service_timesyncd_enabled
Current State	systemd-timesyncd installed but inactive; not running/enabled
Required State	Enable and start systemd-timesyncd for accurate time sync
Risk / Threat Scenario	Incorrect timestamps reduce log integrity, hinder incident response, and break time-based auth.
Compliance Mapping	PIPEDA: reliable audit trails; NIST AU-8, CM-6; CIS logging and monitoring controls.
Remediation (commands)	sudo systemctl enable --now systemd-timesyncd.service; verify with systemctl status.

- **Disable SSH Access via Empty Passwords (High)**

Field	Detail
Rule ID	xccdf_org.ssgproject.content_rule_sshd_disable_empty_passwords
Current State	No PermitEmptyPasswords setting found in sshd_config or config.d
Required State	Explicitly set PermitEmptyPasswords no
Risk / Threat Scenario	If any account has empty password, SSH could allow remote login without credentials.
Compliance Mapping	NIST AC-17, PR.AC-4; CIS SSH hardening; PIPEDA safeguards for remote access.
Remediation (commands)	Create /etc/ssh/sshd_config.d/00-complianceascode-hardening.conf with 'PermitEmptyPasswords no', then sudo systemctl reload sshd.

- **Disable SSH Access via Empty Passwords (PAM link) (High)**

Field	Detail
Rule ID	xccdf_org.ssgproject.content_rule_sshd_disable_empty_passwords
Current State	SSH package installed; sshd_required variable is default 0 (not enforced by profile)
Required State	Confirm sshd is required and hardened; ensure PAM prevents empty passwords
Risk / Threat Scenario	Scanner may show failure due to missing config file even if SSH is not used; but default SSH service still exists.
Compliance Mapping	Same as above; plus configuration management evidence requirements.
Remediation (commands)	Verify sshd service is needed; if yes, enforce profile and harden; if not, remove openssh-server or disable service.

False Positive Investigation (2 findings)

1) systemd-timesyncd failure may be a false positive if time sync is managed by another service (e.g., chrony). Evidence: var_timesync_service set to systemd-timesyncd, but service inactive.

Verification: check 'timedatectl status' and alternative NTP clients. Conclusion: if chrony is active, mark as false positive; otherwise remediate by enabling timesyncd.

2) SSH PermitEmptyPasswords failure may be a false positive if SSH is not intended to run (e.g., VM is local-only). Evidence: openssh-server installed; but no PermitEmptyPasswords line present. Verification: confirm sshd status and requirement; if SSH not required, remove package or disable service; otherwise add explicit configuration.

Remediation Prioritization Matrix

Finding	Severity	Compliance Impact	Exploitation Risk	Remediation Complexity	Tier
Empty password PAM (nullok)	High	High	High	Low	Tier 1 (0–30d)
Grub UEFI password	High	High	High (physical access)	Medium	Tier 1 (0–30d)
Timesyncd inactive	High	Medium	Medium	Low	Tier 1 (0–30d)
SSH PermitEmptyPasswords missing	High	High	High	Low	Tier 1 (0–30d)
SSHD requirement variable	High	Medium	Medium	Low	Tier 2 (30–90d)

Continuous Monitoring Recommendations

- Schedule OpenSCAP scans weekly and after major changes (patching, new services).
- Integrate scan results into SIEM (e.g., ELK/Graylog) for trend analysis and alerting.
- Enforce change management: treat baseline drift as an incident; require justification and approval for deviations.
- Maintain SCAP content versioning and document profile selection for audit evidence.

Self-Assessment & Reflection

- 1) Scanner accuracy: Automated scanning is efficient but may report false positives due to missing config files or alternate controls. Manual verification is necessary for high-impact findings.
- 2) Manual vs automated: Automation provides coverage; manual checks validate context and reduce audit risk.
- 3) Compliance vs security: Compliance is a minimum baseline; security requires threat modeling and risk-based decisions.
- 4) Tool selection: OpenSCAP is cost-free and standards-aligned; commercial tools may provide broader asset discovery and dashboards.
- 5) Ethics: Scanning must remain within authorized lab scope; unauthorized scanning is illegal and unethical.